

ASSEMBLEIA DA REPÚBLICA**Lei n.º 59/2025, de 22 de outubro**

Sumário: Autoriza o Governo a transpor a Diretiva (UE) 2022/2555, relativa a medidas destinadas a garantir um elevado nível comum de cibersegurança na União.

Autoriza o Governo a transpor a Diretiva (UE) 2022/2555, relativa a medidas destinadas a garantir um elevado nível comum de cibersegurança na União

A Assembleia da República decreta, nos termos da alínea c) do artigo 161.º da Constituição, o seguinte:

Artigo 1.º

Objeto

A presente lei autoriza o Governo a aprovar o regime jurídico da cibersegurança, transpondo a Diretiva (UE) 2022/2555 do Parlamento Europeu e do Conselho, de 14 de dezembro de 2022, destinada a garantir um elevado nível comum de cibersegurança em toda a União.

Artigo 2.º

Sentido e extensão

A autorização referida no artigo anterior tem como sentido e extensão:

- a) Aprovar o regime jurídico da cibersegurança, transpondo, para a ordem jurídica interna, a Diretiva (UE) 2022/2555 do Parlamento Europeu e do Conselho, de 14 de dezembro de 2022, relativa a medidas destinadas a garantir um elevado nível comum de cibersegurança na União, que altera o Regulamento (UE) n.º 910/2014 e a Diretiva (UE) 2018/1972 e revoga a Diretiva (UE) 2016/1148 (Diretiva SRI 1);
- b) Executar, na ordem jurídica interna, as obrigações decorrentes do Regulamento (UE) 2019/881 do Parlamento Europeu e do Conselho, de 17 de abril de 2019, relativo à ENISA (Agência da União Europeia para a Cibersegurança) e à certificação da cibersegurança das tecnologias da informação e comunicação e que revoga o Regulamento (UE) n.º 526/2013 (Regulamento Cibersegurança), implementando um quadro nacional de certificação da cibersegurança;
- c) Proceder à nona alteração à Lei de Segurança Interna, aprovada pela Lei n.º 53/2008, de 29 de agosto;
- d) Proceder à segunda alteração à Lei do Cibercrime, aprovada pela Lei n.º 109/2009, de 15 de setembro, alterada pela Lei n.º 79/2021, de 24 de novembro;
- e) Proceder à segunda alteração à Lei das Comunicações Eletrónicas, aprovada pela Lei n.º 16/2022, de 16 de agosto, alterada pelo Decreto-Lei n.º 114/2024, de 20 de dezembro.

Artigo 3.º

Sentido e extensão relativos ao disposto na alínea a) do artigo anterior

A autorização legislativa referida na alínea a) do artigo anterior é concedida com os seguintes sentido e extensão:

- a) Ampliar o âmbito de aplicação do regime jurídico da cibersegurança, excluindo as entidades nos domínios da segurança nacional, da segurança pública, da defesa e dos serviços de informações, mas abrangendo uma parte substancial da Administração Pública, incluindo os serviços técnicos e administrativos dos órgãos de soberania, e ainda as designadas entidades essenciais, importantes e públicas relevantes, distinguidas mediante um conjunto de critérios relacionados com a importância, a dimensão e a tipologia da entidade, incluindo, designadamente:
 - i) No que respeita às entidades essenciais, o respetivo grau de exposição a riscos, a dimensão da entidade, a importância da sua atividade e a probabilidade de ocorrência de incidentes e a sua gravidade, social e económica;

ii) No que respeita a entidades importantes, a não aplicação dos critérios aplicáveis às entidades essenciais;

iii) No que respeita a entidades públicas relevantes de Grupo A, a não aplicação dos critérios aplicáveis às entidades essenciais ou importantes, a natureza da entidade pública e a sua dimensão;

iv) No que respeita a entidades públicas relevantes de Grupo B, a não aplicação dos critérios aplicáveis às entidades essenciais ou importantes, a natureza da entidade pública e a sua dimensão;

b) Habilitar o desenvolvimento dos instrumentos estruturantes da segurança do ciberespaço, incluindo:

i) A Estratégia Nacional de Segurança do Ciberespaço, que definirá as prioridades e os objetivos estratégicos nacionais em matéria de cibersegurança;

ii) O Plano Nacional de Resposta a Crises e Incidentes de Cibersegurança em grande escala, regu-lando e aperfeiçoando a gestão deste tipo de incidentes;

iii) O Quadro Nacional de Referência para a Cibersegurança, reunindo e divulgando as normas, padrões e boas práticas na gestão da Cibersegurança;

c) Prever um novo quadro institucional da segurança do ciberespaço, incluindo, designadamente:

i) O Conselho Superior de Segurança do Ciberespaço, na qualidade de órgão consultivo do Primeiro-Ministro no domínio da cibersegurança;

ii) O Centro Nacional de Cibersegurança, na qualidade de autoridade nacional de cibersegurança;

iii) O Gabinete Nacional de Segurança e a Autoridade Nacional de Comunicações, na qualidade de autoridades nacionais setoriais de cibersegurança;

iv) A Autoridade de Supervisão de Seguros e Fundos de Pensões, a Comissão do Mercado de Valores Mobiliários e o Banco de Portugal, na qualidade de autoridades nacionais especiais de cibersegurança;

d) Prever um novo regime aplicável às avaliações de segurança e propostas emitidas pela Comissão de Avaliação de Segurança do Ciberespaço, bem como às decisões, cuja competência é atribuída ao membro do Governo responsável pela área da cibersegurança, de aplicação de restrições provisórias à utilização, a cessação de utilização ou exclusão de equipamentos, componentes ou serviços de tecnologias de informação e comunicação, considerados de elevado risco para a segurança do ciberespaço nacional;

e) Estabelecer um novo regime de gestão dos riscos de cibersegurança, incluindo, designadamente:

i) A previsão de obrigações próprias dos órgãos de gestão, direção e administração das entidades abrangidas;

ii) A previsão de um sistema de gestão de riscos de cibersegurança, constituído das medidas técnicas, operacionais e organizativas adequadas para gerir os riscos de cibersegurança;

iii) A imposição de uma análise do risco residual, da emissão de um relatório anual sobre cibersegurança e da designação de um responsável de cibersegurança e de um ponto de contacto permanente nas entidades abrangidas;

f) Prever um novo regime de prevenção e tratamento de incidentes de cibersegurança, incluindo, designadamente, o dever de as entidades abrangidas notificarem qualquer incidente significativo à autoridade de cibersegurança competente;

g) Prever um novo regime de supervisão e execução em matéria de cibersegurança, que habilite a autoridade de cibersegurança competente a supervisionar o cumprimento do regime e a adotar, em relação às entidades abrangidas, medidas adequadas à prossecução daquele cumprimento, submetidas ao princípio da proporcionalidade e a garantias procedimentais, designadamente:

i) Inspeções no local e a supervisão remota;

ii) Auditorias de segurança e *ad hoc*;

- iii) Verificações de segurança;
- iv) Pedidos de informações e de apresentação das provas demonstrativas da aplicação das políticas e procedimentos de cibersegurança;
- v) Advertências, ordens ou instruções vinculativas;
- vi) Suspensão de certificação, autorização ou licença relativa à atividade da entidade;
- vii) Solicitação ao órgão competente da suspensão da autorização ou da licença relativa à atividade da entidade;
- viii) Bloqueio e redirecionamento de endereços de protocolo IP;
- h) Estabelecer um novo regime sancionatório em matéria de cibersegurança, incluindo, designadamente, a previsão de um regime contraordenacional, a previsão da possibilidade de as entidades solicitarem fundamentadamente à autoridade de cibersegurança competente a dispensa da aplicação de coimas durante 12 meses a contar da entrada em vigor do regime, e ainda a impugnabilidade das decisões da autoridade de cibersegurança competente no âmbito de processos de contraordenação para os tribunais judiciais.

Artigo 4.º

Sentido e extensão relativos ao disposto na alínea c) do artigo 2.º

A autorização legislativa referida na alínea c) do artigo 2.º é concedida com o sentido e extensão de prever e regular um novo gabinete de crise, visando assegurar a condução de crises de cibersegurança com impacto na segurança interna.

Artigo 5.º

Sentido e extensão relativos ao disposto na alínea d) do artigo 2.º

A autorização legislativa referida na alínea d) do artigo 2.º é concedida com o sentido e extensão de proceder à despenalização de factos suscetíveis de consubstanciar os crimes de acesso ilegítimo e de interceção ilegítima mediante a verificação cumulativa de um conjunto de circunstâncias, incluindo, designadamente:

- a) O agente atuar com a intenção única de identificar a existência de vulnerabilidades em sistema de informação, produtos e serviços de tecnologias de informação e comunicação, que não tenham sido criadas por si ou por terceiro de quem dependa, e com propósito de, através da sua divulgação, contribuir para a segurança do ciberespaço;
- b) O agente não atuar com o propósito de obter vantagem económica ou promessa de vantagem económica decorrente da sua ação, sem prejuízo da remuneração que aquele obtenha como contrapartida da sua atividade profissional;
- c) O agente comunicar, imediatamente após a sua ação, as eventuais vulnerabilidades identificadas, ao proprietário ou pessoa por ele designada para gerir o sistema de informação, produto ou serviço de tecnologias de informação e comunicação, ao titular de quaisquer dados obtidos e que se encontrem protegidos ao abrigo da legislação aplicável em matéria de proteção de dados pessoais, designadamente, o Regulamento Geral de Proteção de Dados (RGPD), aprovado pelo Regulamento (UE) 2016/679 do Parlamento Europeu e do Conselho, de 27 de abril de 2016, a Lei n.º 26/2016, de 22 de agosto, a Lei n.º 58/2019, de 8 de agosto, e a Lei n.º 59/2019, de 8 de agosto;
- d) A atuação do agente ser proporcional aos seus propósitos e estritamente limitada pelos mesmos, bastando-se com as ações necessárias à identificação das vulnerabilidades e não provocando:
 - i) Uma perturbação ou interrupção do funcionamento do sistema ou serviço em causa;
 - ii) A eliminação ou deterioração de dados informáticos ou a sua cópia não autorizada;

iii) Qualquer efeito prejudicial, danoso ou nocivo sobre a pessoa ou entidade afetada, direta ou indiretamente, ou sobre quaisquer terceiros, excluindo os efeitos correspondentes ao próprio acesso ilegítimo ou interceção ilegítima, nos termos previstos nos artigos 6.º e 7.º da Lei n.º 109/2009, de 15 de setembro, e ainda os que resultariam já, com elevada probabilidade, da própria vulnerabilidade detetada ou da sua exploração;

e) A atuação do agente não consubstanciar a violação de dados pessoais protegidos ao abrigo da legislação aplicável em matéria de proteção de dados pessoais, designadamente, do Regulamento (UE) 2016/679 do Parlamento Europeu e do Conselho, de 27 de abril de 2016, da Lei n.º 58/2019, de 8 de agosto, e da Lei n.º 59/2019, de 8 de agosto.

Artigo 6.º

Duração

A autorização concedida pela presente lei tem a duração de 180 dias.

Aprovada em 30 de setembro de 2025.

O Presidente da Assembleia da República, José Pedro Aguiar Branco.

Promulgada em 15 de outubro de 2025.

Publique-se.

O Presidente da República, MARCELO REBELO DE SOUSA.

Referendada em 16 de outubro de 2025.

O Primeiro-Ministro, Luís Montenegro.

119676695